

● 1 Ago 2022

01

US\$ 190M

Nomad Bridge

“O primeiro hack ‘democrático’ — centenas copiaram”

ZERO-HASH BYPASS • CRITICAL

0 que aconteceu

02

Nomad era uma bridge cross-chain que usava **optimistic verification** — um modelo onde mensagens são aceitas após um período sem disputa.

Um upgrade de rotina **inicializou o trusted root como 0x00**. O contrato usava **mapping** para checar se um root era aceito — e em Solidity, valores não-inicializados retornam **0**.

Resultado: **acceptableRoot[0x00] = true** por padrão. Qualquer mensagem com root 0x00 era válida.

O mais surpreendente: após o primeiro exploit, **centenas de pessoas** simplesmente copiaram a transação, trocando apenas o endereço de destino, e drenaram os US\$190M restantes.

03

Contrato Vulnerável

INHA VULNERÁVEL

SOLIDITY / VULNERABLE

256)

"not

```
ceptableRoot(0x00) → TRUE // Qualquer mensagem é válida!  
_send(_message); } }
```

Lição

Testes de invariante devem cobrir **estado pós-upgrade**. Nunca confie em valores default de mappings para segurança.

Como o ataque funcionou

PASSO 1

Upgrade de rotina no contrato Replica



PASSO 2

Trusted root inicializado como 0x00



PASSO 3

mapping(0x00) → default uint256 = 0

confirmAt[0x00] setado como 1 no upgrade

acceptableRoot(0x00) = TRUE



PASSO 4

Atacante envia mensagem com root 0x00

require(acceptableRoot) → PASSA



PASSO 5

Centenas copiam a tx, trocam endereço

"Hack democrático" – US\$190M drenados

Verifique na Blockchain

Uma das transações do Ataque

etherscan.io/tx/0xa5fe9d...6c2e

Contrato Nomad Replica

etherscan.io/address/0xB9233...7bd8

SMARTCONTRACT ENGINEER

Solidity

Lucas Bispo de Oliv

SMARTCONTRACT

Soli

Solidity de f

